

ROYAL HOSPITAL

Cybersecurity Awareness Campaign

Targeting Nursing Staff: Evolving Threats & Countermeasures

Aligned with ISO/IEC 27001:2022 · NIST SP 800-50 · NHS DSPT v6.0 · UK GDPR

1.0. INTRODUCTION

Threats to the healthcare system keep evolving every year, and healthcare organizations have been a high-value target for cybercriminals due to the sensitivity of patient data and the operational pressures that incentivize security shortcuts. Royal Hospital (RH) operates a network of interconnected systems that includes Application servers, cloud applications, wearable sensors, and departmental workstations. A single compromised account or unpatched device can lead to cascading consequences.

In this report, I have designed a targeted security awareness campaign for nursing staff at RH, addressing the five most prevalent threats facing nurses and the workaround behaviours that heighten organizational risk. The campaign is grounded in usable cybersecurity principles, behavioural theory, and the NHS governance pressure workforce. The primary deliverable is a branching scenario e-learning module that will help nurses learn where they may have been susceptible to attacks.

1.1. USER GROUP ANALYSIS & SECURITY CHALLENGES

Nursing Staff - registered nurses and healthcare assistants across RH’s Outpatient, Inpatient, and Pharmacy departments are selected as the target group for this campaign. Nurses access the RH Application Server (where patient records, prescriptions, etc., are kept), interact with cloud applications and wearable sensor data, and operate under constant time pressure, making them the most frequently targeted clinical group in the NHS phishing campaigns [1]. Their scale within the Trust means behaviour changes yield disproportionate security improvements.

1.2. Security Challenges and Workarounds; I have identified five principal challenges, and mapped them to ISO27001:2022 Annex A controls and the NHS DSPT:

Threats	Common Workarounds	ISO 27001 Controls	Root Cause

Phishing/Social Engineering	Acting on urgency, clicking unverified links	A.8.23, A.6.3	Authority bias [2], time pressure
Credential Sharing	Sharing logins with trusted colleagues	A.9.2, A.9.4	Role interdependency; usability friction
BYOD/Data handling	WhatsApp for patient images on personal devices	A.8.1, UK GDPR Article 5	Convenience; GDPR unawareness
Authentication Fatigue	Leaving workstations unlocked between tasks	A.9.4	Compliance budget exhaustion
Ransomware Response	Restarting infected machines; continuing use	A.5.26	Absent incident training

These workarounds are rational responses to poor system design. Beautelement et al.'s compliance budget [3] explains non-compliance as a consequence of finite cognitive resources; when security demands exceed the budget, controls are bypassed. Individually, each incident risks patient data confidentiality; collectively, they expose the RH to lateral propagation, as seen in the 2017 Wannacry Attack, which cost the NHS 92 million pounds and disrupted 80 Trusts [4].

2.0. SECURITY AWARENESS CAMPAIGN DESIGN

Overview: The “Cybersafe Nursing” campaign is designed to address the five threats identified above through a psychologically-informed, low-friction awareness programme. The campaign is rooted in the COM-B model of behaviour change [6], addressing Capability (knowledge), Opportunity (environment), and Motivation (attitude).

2.1. PRIMARY ARTEFACTS: BRANCHING SCENARIO E-LEARNING MODULE

The Primary artefact is the mobile-responsive branching scenario e-learning module (HTML5, no installation needed). Five scenarios were drawn from the RH ward contexts, which present realistic decision points and deliver immediate, evidence-referenced feedback. This design applies Lave and Wenger’s situated learning theory [5]: embedding training in authentic clinical situations improves transfer of practice far beyond policy documents. The COM-B model underpins the structure.

2.2. SCENARIOS COVERED

- **Intro page:** CyberSafe Training programme introductory page for nurses, detailing the brief summary of the training



Figure 1-CYBERSAFE Intro Page

- **Scenario 1: The Urgent Email:** Identifying and reporting NHS spear-phishing (Social Engineering)

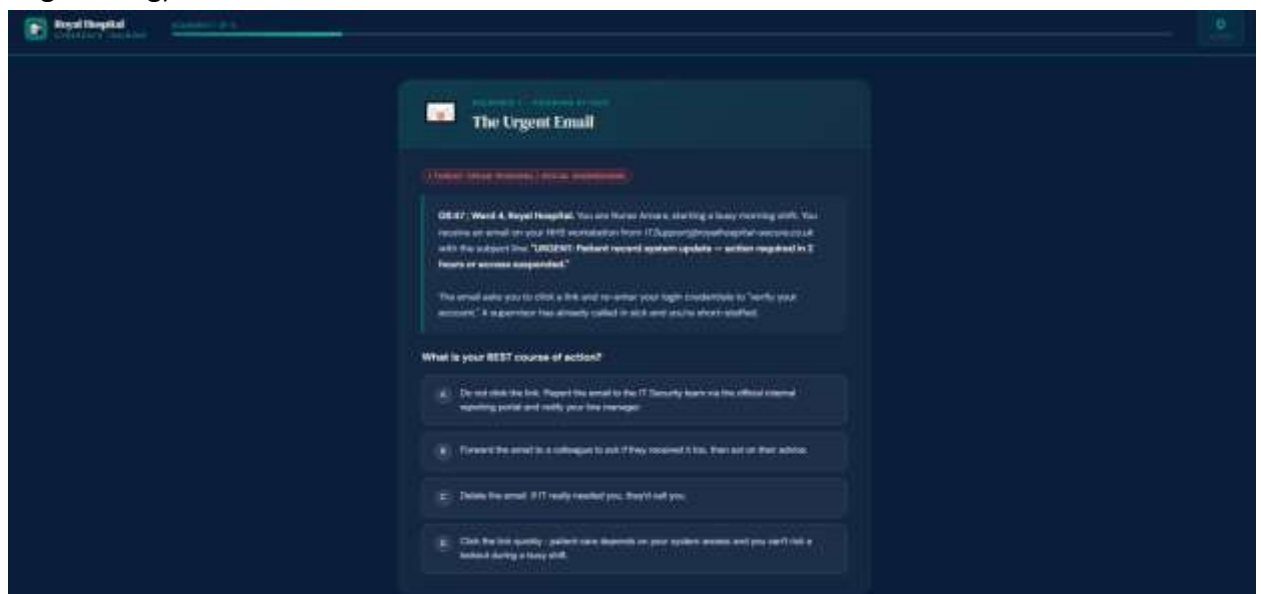


Figure 2-Scenario 1 – Urgent Email

- **Scenario 2: The Password Request:** Refusing credential sharing; using emergency access provisioning (Access Control)

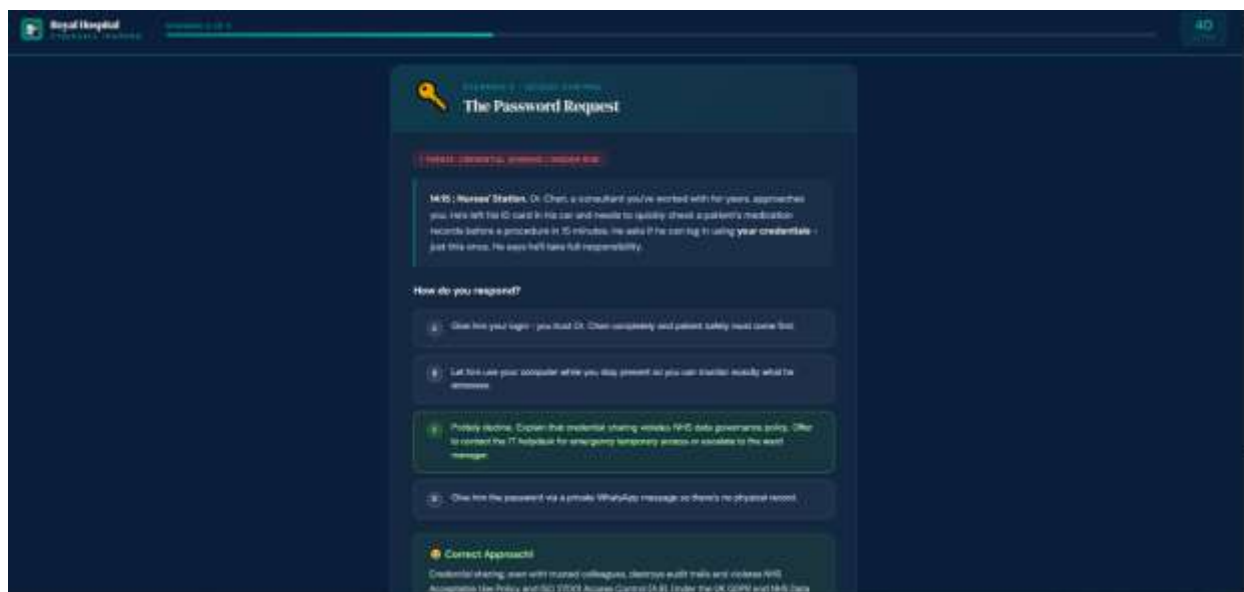


Figure 3 - Scenario 2 – Password Request

- **Scenario 3:** The Patient Photo: Rejecting BYOD for patient data; approved NHS tools (UK GDPR/BYOD)

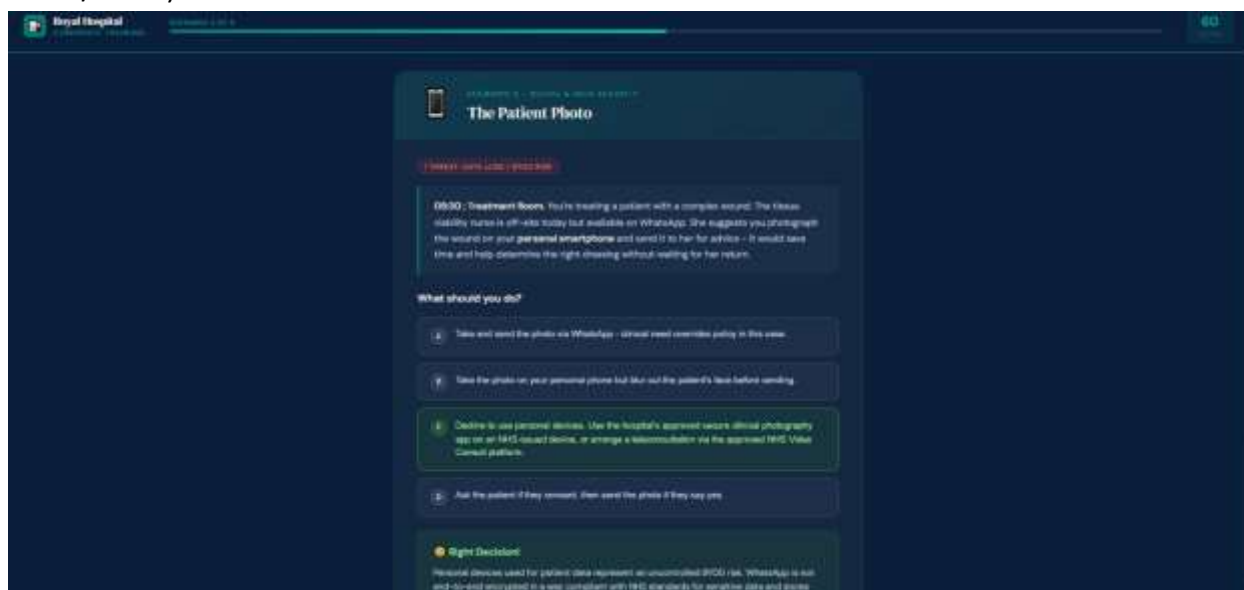


Figure 4- Scenario 3 - Patient Photo

- **Scenario 4:** The Shared Workstation: Managing authentication fatigue via formal escalation (Security Fatigue)

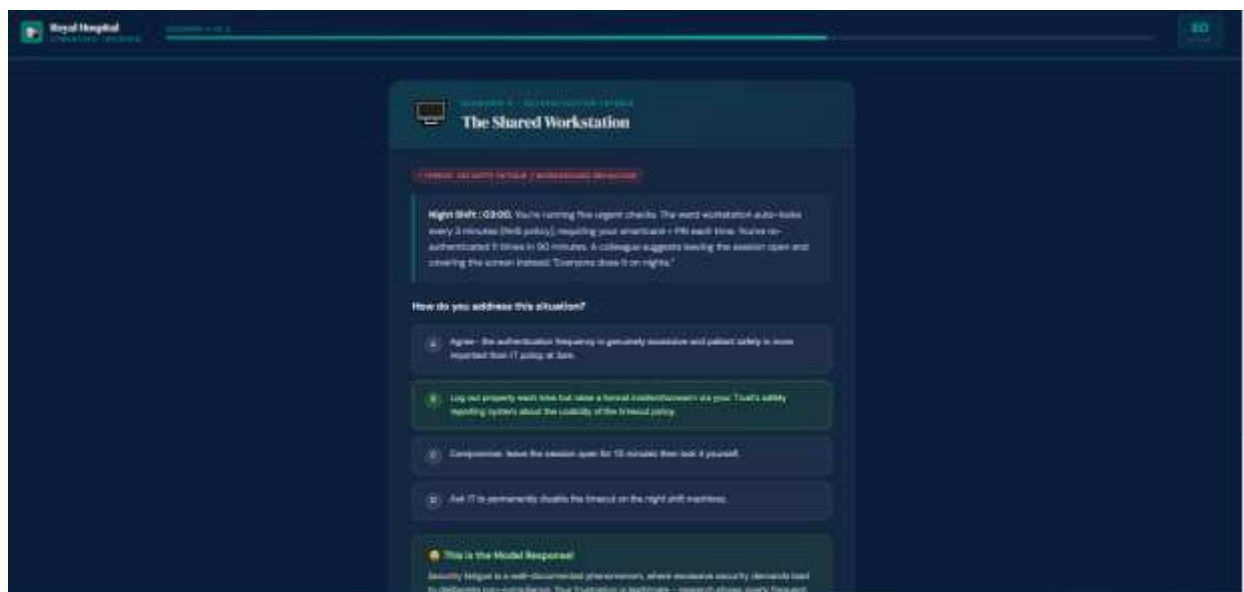


Figure 5 -Scenario 4 - The shared Workstation

- **Scenario 5 – The Looked Screen: Correct ransomware isolation incident reporting (incident Response)**

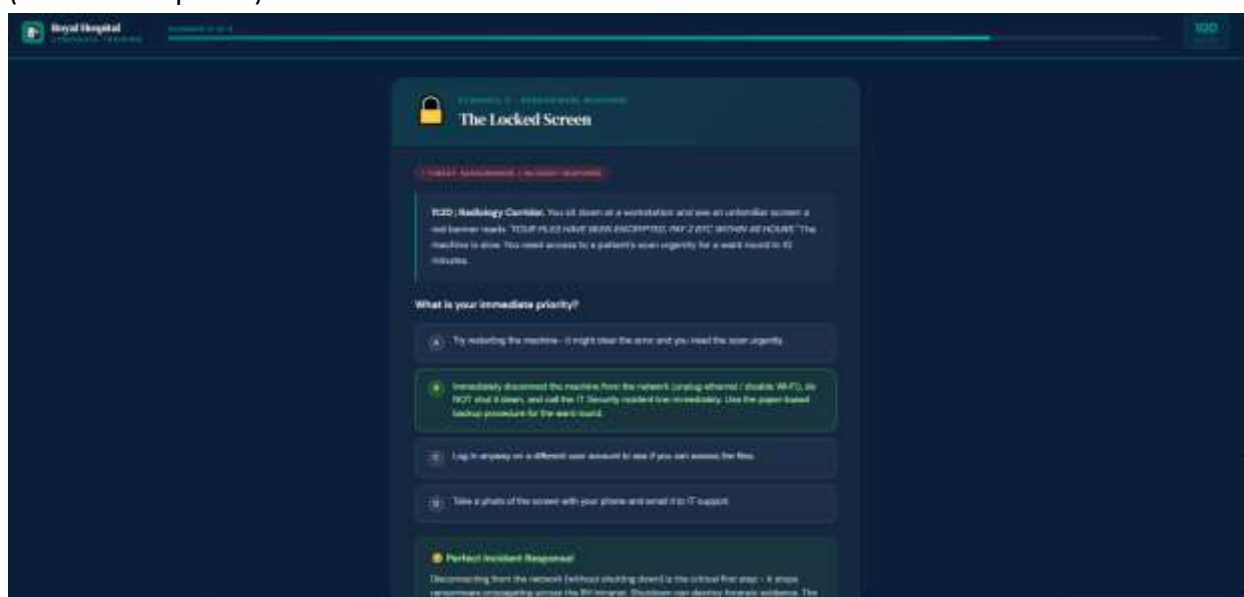


Figure 6- Scenario 5 - The Locked Screen

- **Final Result Page – The feedback page: Final score and recommendations of the training.**

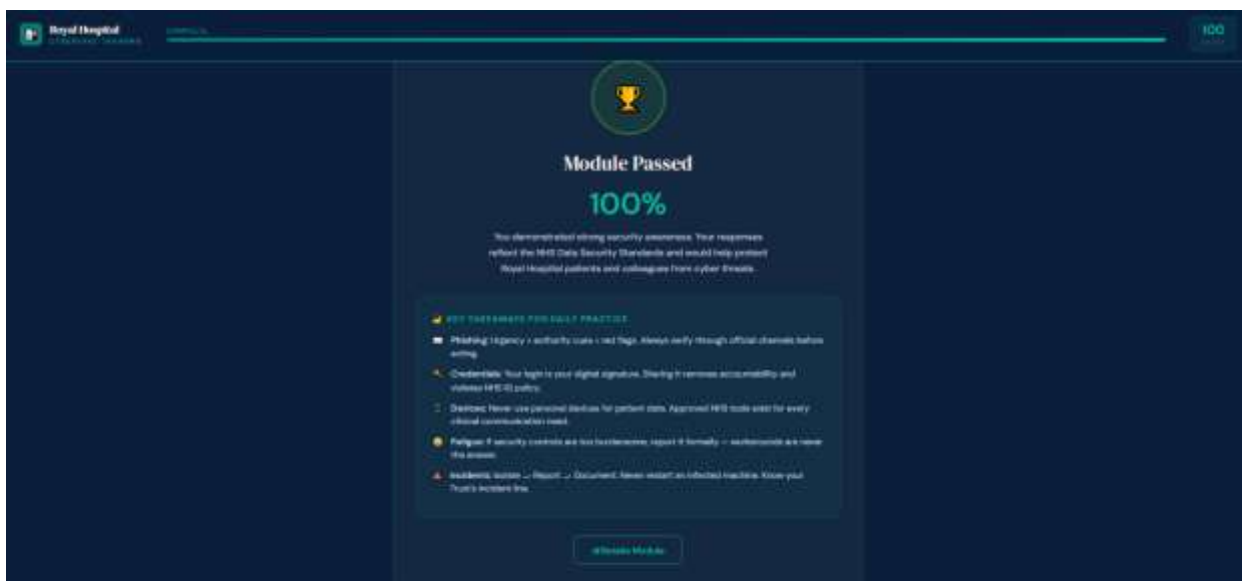


Figure 7 - Final Result Page and Takeaway

2.3. SUPPORTING CAMPAIGN ELEMENTS

Elements	Description	Threat Addressed
Phishing Simulations	Monthly simulated NHS emails; failed clicks redirect to learning(no punishment)	Phishing, Social Engineering
Poster Series (x3)	Ward posters: 'PAUSE before you click'. 'Your login is your signature. 'Report, don't restart.'	All five threat areas
Pocket Reference Card	Laminated cards; IT Security incident line, DSPT reporting link, approved tool list	Incident Response, BYOD

2.4. MEASURABLE OUTCOMES – KIRKPATRICK FOUR-LEVEL EVALUATION [7]

Level	Kirkpatrick	Metric	Target
1	Reaction	Post-module satisfaction survey (5-point Likert)	Mean $\geq 4.0/5.0$
2	Learning	Module quiz score (pre/post)	$\geq 20\%$ gain; 80% pass rate

3	Behaviour	Phishing click rate; credential sharing incidents	50% click-rate reduction at 6 months
4	Results	Human-error security incidents; DSPT score	DSPT 'Standards Met' within 12 months

3.0. CONCLUSION

- 3.1. RATIONALE FOR DESIGN DECISIONS:** The campaign treats non-compliance as a system failure, not individual negligence. Each e-learning scenario acknowledged the legitimate pressure behind each workaround before redirecting to compliant behaviour; a technique recommended by NCSC [8] to avoid positioning security as adversarial to clinical work. The branching format, grounded in Adam's and Sasse's [9] finding that understanding why a behaviour is risky outperforms rule-enforcement, delivers knowledge transfer without coercion. Five-minute micro-sessions are deliverable during handover periods, avoiding the excessive overhead identified by Beautelement et al. [3] as the primary driver of non-compliance.
- 3.2. AVOIDING UNDUE BURDEN;** The module requires no installation, imposes no penalty for wrong answers, and includes a formal reporting mechanism for staff usability barriers, communicating matters to governance. This directly addresses security fatigue [10] by treating authentication friction as a design problem to escalate, not a policy to endure silently.
- 3.3. STRATEGIC ALIGNMENT:** The campaign satisfies NHS DSPT Standard 9 (mandatory awareness training), ISO 27001:2022 A.6.3 Information Security Awareness and Training)[11], and the NCSC 10 Steps 'User Education' principle. Longitudinal evaluation at 3, 6, and 12 months using the Kirkpatrick metrics above will enable iterative improvement and demonstrate compliance with the Information Commissioner's Office under UK GDPR Article 5(1)(f).

REFERENCES

- [1] NHS Digital, 'Cyber Threat Intelligence: Annual Report 2023,' NHS England, London, 2023.
- [2] R. B. Cialdini, *Influence: Science and Practice*, 5th ed. Allyn & Bacon, Boston, MA, 2001.
- [3] A. Beautelement, M. A. Sasse, and M. Wonham, 'The compliance budget,' in *Proc. NSPW '08*, Lake Tahoe, CA, 2008, pp. 47–58.
- [4] NHS Digital, 'Investigation: WannaCry Cyber Attack and the NHS,' Dept. of Health and Social Care, London, 2018.
- [5] J. Lave and E. Wenger, *Situated Learning: Legitimate Peripheral Participation*. Cambridge Univ. Press, 1991.
- [6] S. Michie, M. M. van Stralen, and R. West, 'The behaviour change wheel,' *Implementation Science*, vol. 6, no. 42, 2011.
- [7] D. L. Kirkpatrick, *Evaluating Training Programs: The Four Levels*, 3rd ed. Berrett-Koehler, San Francisco, CA, 2006.
- [8] NCSC, 'Security Awareness and Training: A Good Practice Guide,' NCSC, London, 2021.
- [9] A. Adams and M. A. Sasse, 'Users are not the enemy,' *Commun. ACM*, vol. 42, no. 12, pp. 40–46, 1999.
- [10] B. Stanton et al., 'Security fatigue,' *IT Professional*, vol. 18, no. 5, pp. 26–32, 2016.
- [11] ISO/IEC 27001:2022, *Information Security Management Systems — Requirements*. ISO, Geneva, 2022.